

Guía Metodológica de la Encuesta sobre Indicadores CWE

1. Objetivo general

La presente guía describe la metodología para la aplicación, explotación e interpretación de la “Encuesta Integral sobre Indicadores CWE y Gestión de Debilidades de Software y Hardware”. Su propósito es permitir que distintos actores (organismos públicos, asociaciones sectoriales, grupos de investigación y empresas) apliquen la encuesta de forma homogénea y rigurosa, favoreciendo la comparabilidad de resultados.

El marco conceptual se asienta en el uso de CWE como taxonomía estándar para debilidades, combinado con CVE, CVSS y listas priorizadas (Top 25, KEV, MIHW), en línea con las mejores prácticas internacionales.

2. Población objetivo y unidades de análisis

La unidad de análisis es la **organización** (empresa, organismo público, entidad sin ánimo de lucro) que gestione sistemas de información relevantes para la prestación de servicios digitales, infraestructuras críticas o tratamiento significativo de datos.

Se recomienda focalizar inicialmente en:

- Organismos públicos con sistemas bajo el ENS.
- Operadores de servicios esenciales o entidades reguladas bajo NIS2.
- Sectores de alta criticidad (sanidad, energía, transporte, finanzas, telecomunicaciones).
- Proveedores tecnológicos clave (desarrolladores de software, integradores, fabricantes de hardware).

Cada cuestionario debe ser cumplimentado por una persona con visibilidad transversal suficiente: CISO, responsable de seguridad, responsable de arquitectura o figura equivalente. Se puede admitir una respuesta conjunta de un pequeño equipo, siempre que se documente.

3. Diseño de la encuesta

La encuesta se estructura en 11 bloques:

1. Datos generales.
2. Gobierno y estrategia.
3. Procesos de identificación y clasificación.
4. Uso de listas CWE priorizadas (Top 25, KEV, MIHW).
5. Indicadores y métricas internas.
6. Integración en el ciclo de vida de desarrollo.
7. Gestión de riesgos y cumplimiento normativo.
8. Capacidades, formación y cultura.
9. Tecnología, herramientas y datos.
10. Perspectiva futura, inversión e impacto.
11. Comentarios abiertos.

La mayoría de preguntas son cerradas (opción única o múltiple) para facilitar el análisis estadístico, pero se incluyen campos abiertos estratégicamente para captar matices y casos de uso singulares.

4. Modalidad de recogida de datos

Se recomienda aplicar la encuesta mediante:

- Cuestionario en línea (formularios web o herramientas de survey profesionales).
- Entrevistas semiestructuradas, en organizaciones clave, usando el cuestionario como guion.

Para maximizar la calidad de las respuestas:

- Anticipar a las organizaciones el contenido general y el tiempo estimado (20–30 minutos).
- Asegurar la confidencialidad y explicar el uso exclusivo de los datos para análisis agregados.
- Ofrecer a cada organización un breve informe de retorno (benchmark anónimo) como incentivo.

5. Codificación y tratamiento de las respuestas

5.1. Codificación de preguntas cerradas

Cada respuesta cerrada debe codificarse numéricamente. Por ejemplo:

- Escalas de frecuencia (Nunca, Raramente, A veces, Frecuentemente, Siempre) → 1–5.
- Grado de madurez (No existe, Inicial, Parcial, Definido, Optimizado) → 0–4.
- Grado de acuerdo (Totalmente en desacuerdo → 1, Totalmente de acuerdo → 5).

La codificación debe documentarse en un diccionario de datos central, que se compartirá con todos los equipos de análisis.

5.2. Preguntas de selección múltiple

Las preguntas de selección múltiple se codificarán mediante variables binarias (sí/no) por opción, o mediante un esquema de multirrespuesta, según el software utilizado.

5.3. Respuestas abiertas

Las respuestas abiertas pueden ser objeto de análisis cualitativo (codificación temática) y, en la medida de lo posible, se pueden mapear a categorías CWE o factores organizativos.

6. Indicadores derivados (IGM y otros índices)

Aunque la encuesta no exige a las organizaciones calcular nada durante el llenado, sus respuestas permiten construir varios índices agregados, entre ellos el **Índice de Gestión de Debilidades (IGM)**.

6.1. Índice de Gestión de Debilidades (IGM)

El IGM pretende capturar, en una escala normalizada, el grado de madurez de la organización en:

- Incorporación de CWE como taxonomía.
- Uso de métricas basadas en debilidades (prevalencia, tiempo de remediación, tendencias).
- Integración en procesos de desarrollo, operación y gestión de riesgos.
- Integración en gobierno, cumplimiento y reporte a la alta dirección.

Metodología sugerida:

12. Seleccionar un conjunto de preguntas clave que representen estos aspectos.
13. Asignar pesos (w_i) a cada pregunta, según su relevancia.
14. Normalizar las respuestas (r_i) a una escala homogénea (por ejemplo, 0–1).
15. Calcular $IGM = \sum (w_i * r_i)$.
16. Escalar el resultado a una escala 0–100 para facilitar la interpretación.

Los pesos pueden definirse por consenso de un panel de expertos o mediante análisis estadístico (p.ej., análisis factorial), una vez se disponga de datos suficientes.

6.2. Otros indicadores relevantes

La encuesta permite construir indicadores como:

- Porcentaje de organizaciones que utilizan CWE como taxonomía formal.
- Porcentaje que mapea sistemáticamente vulnerabilidades a CWE.
- Proporción que utiliza el Top 25, KEV y MIHW.
- Porcentaje que dispone de métricas internas basadas en CWE.
- Grado de integración de CWE en análisis de riesgos, cumplimiento y reporte.

Estos indicadores pueden desagregarse por sector, tamaño, tipo de sistemas críticos, etc.

7. Cálculo del ROI en iniciativas CWE

Los datos de la sección 10 (impacto e inversión) permiten alimentar modelos de **retorno de la inversión (ROI)** de iniciativas orientadas a mejorar la gestión de debilidades. Aunque la encuesta por sí sola no produce cifras monetarias precisas, proporciona:

- La existencia (o ausencia) de modelos internos de coste de incidentes.
- La percepción de impacto de la mejora en CWE sobre la resiliencia.
- La tendencia prevista de inversión.

Estos datos pueden combinarse con estudios sectoriales o modelos actuariales para estimar beneficios económicos (reducción de incidentes, tiempo de inactividad, pérdidas reputacionales) asociados a mejoras en IGM.

8. Fiabilidad, validez y sesgos

8.1. Fiabilidad

La fiabilidad se refuerza mediante:

- Preguntas claras y no ambiguas.
- Escalas coherentes en todo el cuestionario.
- Instrucciones precisas al encuestado.

Se recomienda realizar una prueba piloto con un grupo reducido de organizaciones para detectar problemas de interpretación.

8.2. Validez

La validez de contenido se asegura al haber construido el cuestionario a partir de marcos reconocidos internacionalmente (CWE, CVE, CVSS, KEV, MIHW, informes ENISA, etc.). La validez de constructo puede explorarse a posteriori mediante análisis estadístico (por ejemplo, correlaciones entre respuestas y resultados observados).

8.3. Sesgos esperables

Cabe esperar, con toda honestidad científica, que algunas organizaciones respondan de forma más optimista que su realidad, especialmente en temas de madurez. Para mitigar este sesgo:

- Insistir en la confidencialidad y el uso agregado.
- Enfatizar que el objetivo es diagnóstico, no punitivo.
- Contrastar, cuando sea posible, resultados de la encuesta con indicadores observables (por ejemplo, incidentes reportados públicamente).

9. Recomendaciones para la interpretación de resultados

- Evitar comparar organizaciones individuales sin tener en cuenta su contexto (sector, tamaño, criticidad).
- Utilizar los resultados para identificar patrones: por ejemplo, sectores donde el uso de CWE está más avanzado, o tamaños de organización con mayores dificultades.
- Priorizar la lectura de tendencias: a medida que se repita la encuesta en años sucesivos, la variación puede ser más informativa que el nivel absoluto.
- No confundir el IGM con “nivel de seguridad”: se trata de un índice de madurez en gestión de debilidades, que es un componente, no el todo.

10. Frecuencia de aplicación y evolución de la encuesta

Se recomienda aplicar la encuesta con periodicidad anual o bienal. Ello permite:

- Medir la evolución de la madurez en gestión de debilidades.
- Ajustar las preguntas para reflejar nuevas tendencias (por ejemplo, nuevas vistas de CWE, cambios en la metodología del Top 25, nuevos marcos regulatorios).

Se debe mantener un equilibrio saludable entre estabilidad (para series históricas) y actualización (para no ignorar la realidad cambiante de la tecnología y la regulación).

11. Créditos, licenciamiento y uso

Esta guía y el cuestionario asociado pueden utilizarse y adaptarse libremente en contextos de investigación, políticas públicas o programas sectoriales, siempre que se reconozca la autoría y se evite presentarlos como un estándar oficial sin el correspondiente proceso institucional.

La ironía y la prosa literaria son opcionales, pero recomendables para recordar que, incluso entre CWE y CVE, hay vida inteligente.